

KESTRELATTICE

Governed Agent Mesh | Micro-Product

AI Model Provider Vendor Scorecard

Score model providers on governance-relevant criteria before your agents touch them. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

AI Model Provider Vendor Scorecard

For Buyers Governing AI Agents in Production Version 1.0 | © [Your Organization] | Last Updated: [Date]

1. Introduction

This scorecard evaluates AI model providers (AIMPs) against **production-grade governance requirements** for AI agents. It is designed for procurement teams, risk officers, and AI governance committees assessing vendors for deployment in regulated or high-stakes environments.

Scope: - Applies to vendors providing **foundation models, fine-tuned agents, or custom AI systems** integrated into production workflows. - Covers **pre-deployment, runtime, and post-incident governance**. - Aligned with **GDPR, CCPA, NIST AI RMF, ISO/IEC 42001, and enterprise risk frameworks**.

Assessment Criteria: - **Mandatory ([x]/[])** - Non-negotiable for production use. - **Recommended (/)** - Strongly advised; may require additional safeguards. - **Custom ()** - Tailored to organizational risk appetite.

2. Vendor Compliance & Legal Framework

(Ensures adherence to laws, contracts, and internal policies.)

Category	Requirement	Scoring	Notes
1.1 Legal & Regulatory	Provider must comply with all applicable AI/ML regulations (e.g., EU AI Act, sector-specific laws like HIPAA, GLBA).	[x]/[]	Provide signed attestation or audit report.
1.2 Contractual Liability	Explicit limitation of liability for AI-induced harm (e.g., "Provider shall not be liable for indirect damages").	[x]/[]	Review clauses for exclusion of consequential loss.
1.3 Data Sovereignty	Provider must store/process data in compliant jurisdictions / (e.g., no China-based processing for EU data).		Require SOC 2 Type II or ISO 27001 certification for data centers.
1.4 IP & Licensing	Clear end-user license agreement (EULA) for model outputs (e.g., no redistribution rights unless licensed).	[x]/[]	Ensure no hidden sublicensing of third-party data.
1.5 Audit Rights	Provider grants unrestricted access to audit logs, model weights, and training data (if applicable).	[x]/[]	Require quarterly third-party audits.

3. Model Transparency & Explainability

(Ensures accountability and debuggability of AI decisions.)

Category	Requirement	Scoring	Notes
3.1 Model Card	Provider must publish a NIST-aligned model card (data sources, biases, [x]/[] limitations, performance metrics).		Require versioned updates with change logs.
3.2 Bias & Fairness	Provider must disclose bias mitigation efforts (e.g., debiasing techniques, fairness / metrics) and provide bias impact assessments.		Request third-party bias audits for high-risk use cases.
3.3 Input/Output Logging	Provider must log all model inputs/outputs with timestamp, user ID, [x]/[] and context for at least 2 years.		Require immutable audit trails (e.g., blockchain-anchored logs).
3.4 Explainability API	Provider must offer an API for post-hoc explainability (e.g., / SHAP/LIME scores, attention weights).		Critical for regulatory compliance (e.g., EU AI Act Article 13).
3.5 Hallucination Mitigation	Provider must implement fact-checking layers (e.g., retrieval-augmented generation, RAG) and disclose hallucination rates (e.g., <5% for critical decisions). [x]/[]		Require real-time monitoring of hallucinations.

4. Security & Data Governance

(Prevents unauthorized access, data leaks, and adversarial attacks.)

Category	Requirement	Scoring	Notes
4.1 Data Encryption	Provider must encrypt data in transit (TLS 1.3) [x]/[] and at rest (AES-256).		Require customer-controlled keys (e.g., AWS KMS, HashiCorp Vault).

Category	Requirement	Scoring	Notes
4.2 Access Control	Role-based access control (RBAC) with just-in-time (JIT) provisioning for model access.	[x]/[]	Require multi-factor authentication (MFA) for API keys.
4.3 Adversarial Robustness	Provider must test for adversarial attacks (e.g., FGSM, text perturbation) / and disclose resilience metrics.		Request penetration test reports from third parties.
4.4 Supply Chain Security	Provider must vetted dependencies (e.g., no known vulnerable libraries in model training).	[x]/[]	Require SBOM (Software Bill of Materials) for model components.
4.5 Incident Response Plan	Provider must have a published incident response plan with SLA for breach notification (<24h).	[x]/[]	Require quarterly tabletop exercises.

5. Cost & Operational Controls

(Prevents runaway spending and ensures cost transparency.)

Category	Requirement	Scoring	Notes
5.1 Pricing Transparency	Provider must disclose cost drivers (e.g., tokens, inference time, data volume) with no hidden fees.	[x]/[]	Require monthly cost breakdowns in API responses.
5.2 Budget Alerts	Provider must automatically pause API calls when predefined budget limits are exceeded.	[x]/[]	Set daily/weekly caps (e.g., \$10K/day).
5.3 Cost Optimization Tools	Provider must offer API-level cost monitoring (e.g., AWS Cost Explorer for AI).		Prefer vendors with automated cost-saving recommendations.
5.4 Usage Auditing	Provider must log all API calls with cost attribution to user/organization.	[x]/[]	Require exportable logs for reconciliation.

Category	Requirement	Scoring	Notes
5.5 Early Termination	Provider must allow immediate termination of API keys with no data retention beyond contract terms.	[x]/[]	Require automated cleanup scripts for model artifacts.

6. Incident Response & Risk Mitigation

(Ensures rapid containment and recovery from AI-related failures.)

Category	Requirement	Scoring	Notes
6.1 Incident Classification	Provider must classify incidents by severity (P0-P4) with clear escalation paths.	[x]/[]	Require P0 incidents (e.g., data breach) to be handled within 1 hour.
6.2 Post-Incident Review	Provider must conduct root cause analysis (RCA) within 30 days of incident.	[x]/[]	Require publicly disclosed lessons learned.
6.3 AI-Specific SLA	Provider must guarantee <5% downtime for critical AI services (e.g., healthcare, finance).	[x]/[]	Include compensation clauses for SLA breaches.
6.4 Bias Reporting	Provider must have a bias reporting mechanism with / anonymized feedback channels.		Require quarterly bias trend analysis.
6.5 Legal Hold	Provider must freeze all model outputs upon legal request (e.g., subpoena) with no deletion.	[x]/[]	Require signed legal hold agreement.

7. Vendor Performance Metrics

(Measures real-world reliability and governance effectiveness.)

Category	Metric	Target	Scoring	Notes
7.1 Accuracy	Domain-specific accuracy (e.g., 99% for medical diagnosis, 95% for legal contract review).	95% (customizable)	/	Require third-party validation.
7.2 Latency	P99 response time for inference requests.	<500ms (low-latency), <2s (high)	/	Test under production load.
7.3 Uptime	SLA compliance (e.g., 99.9% uptime).	99.9%	[x]/[]	Require third-party monitoring (e.g., UptimeRobot).
7.4 Cost Efficiency	Cost per inference (e.g., \$0.0001/token).	<\$0.0002/token	/	Compare against AWS Bedrock, Mistral, or Anthropic.
7.5 Compliance Audit Score	Third-party compliance score (e.g., ISO 27001, SOC 2).	90/100	[x]/[]	Require latest audit report.

8. Vendor Self-Assessment Checklist

(Providers must complete this to demonstrate compliance.)

Question	Answer (Y/N)	Evidence Required
Does your provider offer immutable audit logs for all model Y interactions?		Signed attestation + sample logs.

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com